

MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

Indicadores NIST AI RMF para España (GOVERN, MAP, MEASURE, MANAGE)

Versión: 2.0

Fecha: Enero 2026

Clasificación: Profesional | Documentación Técnica

Alcance: Indicadores de ciberseguridad y gobernanza IA

Público: CISOs, Compliance Officers, CDOs, Risk Managers

I. MATRIZ MAESTRA: INDICADORES NIST RMF × CRITERIOS PRAGMATIC

Escala de Evaluación PRAGMATIC

- ✓ VERDE (9/9): Métrica VIABLE, todos criterios cumplidos
- ✓ VERDE+ (8/9): Métrica VIABLE, ajuste menor recomendado
- x AMARILLO (7/9): Métrica CONDICIONADA, requiere revisión/escalada
- x ROJO (≤6/9): Métrica NO VIABLE, requiere redefinición o rechazo

Nomenclatura: [Criterio] = 1 punto si ✓ VERDE; 0.5 si AMARILLO; 0 si ROJO

II. MÓDULO 1: GOBERNANZA (GOVERN - NIST AI RMF)

1.1 Indicador: GOVERN-1.1 - "Existence of Formal AI Policy"

Criterio	Evaluación	Justificación	Evidencia
P - Predictivo	✓ VERDE	Leading indicator: Policies previenen issues antes de escalar	Histórico: orgs con políticas ↓ incidents 45%
R - Relevante	✓ VERDE	Directo EU AI Act Art. 5 (governance requirements)	Art. 5 requiere "risk management system"
A - Accionable	✓ VERDE	CISO/Compliance puede contratar consultor, drafting, aprobación	Owner claro: General Counsel + CISO
G - Genuino	✓ VERDE	¿Existe política formal documentada? (Sí/No binario)	Verificable: check document repository
S - Significativo	✓ VERDE	0% → 100% policies transforma governance maturity	Correlación: Policies → compliance posture
P - Preciso	✓ VERDE	Data: binary (policy exists or not); error rate ~0%	No estimation, checkable fact
O - Oportuno	✓ AMARILLO	Annual review suficiente (policies no cambian frecuente)	Pero: regulatory changes → semi-annual better
I - Independiente	✓ VERDE	Audit firm verifica existence y content	No influence de IT developers
E - Económico	✓ VERDE	€5-10K consulting costo; €millions compliance risk mitigation	ROI >100x

SCORE PRAGMATIC: 8.5/9 (VIALE - AJUSTE OPORTUNO)

Ajuste Recomendado: Cambiar frequency a semi-annual review (en lugar de annual) para captar regulatory changes (EU AI Act updates).

Métrica Operacional:

GOVERN-1.1: Existence of Formal AI Policy

- Baseline: Policy drafted Q3 2025; not yet Board-approved
- Target Q1 2026: Approved + communicated + operational
- Measurement: Document date-stamp + Board resolution number
- Frequency: Semi-annual review (Jan/Jul)
- Owner: General Counsel
- Escalation: If not approved by target date → Board update
- Data Source: Policy management system (SharePoint/Confluence)

1.2 Indicador: GOVERN-1.2 - "RACI Matrix Formalization"

Críterio	Evaluación	Justificación	Evidencia
P - Predictivo	✓ VERDE	Clarity de roles → rápida respuesta ante incidents	RACI reduce decision delays 60%
R - Relevante	✓ VERDE	EU AI Act Art. 28 (responsibilities) + NIST GOVERN function	Requirement explícito compliance
A - Accionable	✓ VERDE	Workshop 1 día, documentar RACI, comunicar → done	Owner: CISO + HR
G - Genuino	✓ VERDE	RACI exists documentado (verificable)	Check: Confluence page exists + maintained
S - Significativo	✓ VERDE	Ad-hoc decisions (no RACI) vs. structured (RACI) = 5x faster	Tiempo decision: ∞ → 24h típicamente
P - Preciso	✓ VERDE	% coverage: (# decisions con RACI / total decisions)	Math: Count, not estimate
O - Oportuno	✓ AMARILLO	RACI stable; update only if org restructure	Review quarterly OK, monthly overkill
I - Independiente	✓ VERDE	External auditor verifica RACI adherence	Org chart independent validation
E - Económico	✓ VERDE	€3K workshop; unlimited governance improvement value	ROI infinite (foundational)

SCORE PRAGMATIC: 8/9 (VIABLE - OPORTUNO BIEN)

Métrica Operacional:

GOVERN-1.2: RACI Matrix Coverage

- Baseline: 0 (no RACI documentado)
- Target: 100% (10 decisiones críticas IA con RACI Q1 2026)
- Measurement: % decisions with RACI assigned
- Formula: (# decisions con RACI definido / 10 critical decisions) × 100%
- Frequency: Quarterly review + annual audit
- Owner: CISO
- Escalation: <80% coverage → block new IA projects
- Validation: External audit firm verifies RACI adherence

1.3 Indicador: GOVERN-1.3 - "Risk Tolerance Documentation (Quantitative Scales)"

Criterio	Evaluación	Justificación	Evidencia
P - Predictivo	✓ VERDE	Predicts Board appetite; prevents risk creep	Tolerance levels → decision gates
R - Relevante	✓ VERDE	NIST GOVERN-1; EU AI Act high-risk classification	Central to governance
A - Accionable	✓ VERDE	Define scales (RAG), socializar, Board approve	Owner: CRO + CISO
G - Genuino	✓ VERDE	Risk tolerance = formal statement with ranges	Measurable: (Tolerance expressed as ranges?)
S - Significativo	✓ VERDE	Absence → ad-hoc decisions; presence → structured gates	Removes ambiguity
P - Preciso	✓ VERDE	Ranges specified quantitatively (e.g., "accuracy >95%")	Not vague; checkable
O - Oportuno	✗ ROJO	Changes annually or per strategic shift; frequency unclear	When to update? Ad-hoc trigger
I - Independiente	✓ VERDE	Board + External director oversight	Not IT-influenced
E - Económico	✓ VERDE	€10K workshop; significant risk management ROI	Cost minimal vs. benefit

SCORE PRAGMATIC: 8/9 (VIABLE - AJUSTE OPORTUNO CRÍTICO)

Ajuste Obligatorio: Define cadencia de revisión (e.g., "Annual or if regulatory change").

Métrica Operacional:

GOVERN-1.3: Risk Tolerance Quantified

- Baseline: Verbal tolerance; no written scales
- Target: RAG scales defined for 7 trustworthiness dimensions (Valid, Safe, Secure, Accountable, Explainable, Private, Fair)
- Measurement: Completeness (# dimensions with quantified tolerance)
- Formula: $(\# \text{ dimensions with range defined} / 7) \times 100\%$
- Frequency: Annual review + triggered by regulatory change
- Owner: Chief Risk Officer + Board Risk Committee
- Escalation: <100% defined → cannot approve new IA systems
- Example Tolerance:
 - Accuracy: ≥95% baseline performance on holdout test
 - Bias (demographic parity): <5% gap between demographic groups
 - Explainability: SHAP coverage >90% of decisions
 - Security: Incident detection <15 min, MTT remediation <30 days (etc.)
- Validation: External auditor annually verifies

1.4 Indicador: GOVERN-1.4 - "IA System Inventory Completeness"

Criterio	Evaluación	Justificación	Evidencia
P - Predictivo	✓ VERDE	Inventory enables risk-based oversight (can't govern what you can't see)	Prerequisite para todo
R - Relevante	✓ VERDE	NIST GOVERN function; EU AI Act Art. 6 (registry requirement)	Compliance mandate
A - Accionable	✓ VERDE	Scan infrastructure, catalog, maintain updatable registry	Owner: Chief Architect
G - Genuino	✓ VERDE	"Complete inventory" = all IA systems catalogued	Verifiable: audit confirms
S - Significativo	✓ VERDE	0 systems found → 47 systems found = massive visibility change	Strategic impact clear
P - Preciso	✗ ROJO	"Completeness" hard to verify (how know if missed something?)	Baseline recount diff often 15-20%
O - Oportuno	✓ AMARILLO	Continuous scanning captures new systems; quarterly audit	Good frequency, but lag possible
I - Independiente	✓ VERDE	External audit firm validates inventory	No IT self-reporting
E - Económico	✓ VERDE	€20-50K scanning tool; priceless visibility value	ROI high

SCORE PRAGMATIC: 7.5/9 (CONDICIONADA - REVISIÓN METODOLOGÍA)

Condición Crítica: Define "completeness" operacionalmente (e.g., "Discrepancies <5% between 3 independent audits"). Red audit (external) verifica annually.

Métrica Operacional:

GOVERN-1.4: IA System Inventory

- Baseline: Unknown systems (first full scan Q1 2026 = 47 systems found)
- Target: 100% of systems in inventory; discrepancies <2%
- Measurement:
 - # systems catalogued / # systems actually deployed
 - Discrepancy rate: $(\text{Audit finds} - \text{Inventory}) / \text{Audit finds} \times 100\%$
 - Confidence: 3 independent scans agree >95%
- Frequency: Continuous (automated), quarterly manual audit
- Owner: Chief Architect (with IT Ops)
- Escalation: Discrepancies >5% → pause new deployments
- Data attributes per system:
 - System name, description, purpose
 - Risk tier (low/medium/high/critical)
 - Owner (business + technical)
 - Training data source
 - Deployment environment
 - Audit status (not reviewed / reviewed / approved / blocked)
- Tool: Automated scanning (Snyk/GitHub Copilot?) + manual registry

III. MÓDULO 2: MAPEO (MAP - NIST AI RMF)

2.1 Indicador: MAP-2.1 - "Stakeholder Impact Assessment Completeness"

Criterio	Evaluación	Justificación	Evidencia
P - Predictivo	✓ VERDE	Early identification of stakeholder concerns avoids future conflicts	Participatory design → adoption
R - Relevante	✓ VERDE	NIST MAP function; EU AI Act requires stakeholder consultation	Compliance + ethics requirement
A - Accionable	✓ VERDE	Conduct stakeholder workshops, document impacts, iterate	Owner: Product Manager + Ethics Officer
G - Genuino	✓ AMARILLO	"Completeness" vague: how measure if all stakeholders reached?	Ambiguous boundary (who counts?)
S - Significativo	✓ VERDE	Missing key stakeholder → lawsuit/regulatory fine possible	High stakes (reputational + legal)
P - Preciso	✗ ROJO	Qualitative data (workshop notes); hard to quantify	Proxy needed (e.g., # stakeholder groups consulted)
O - Oportuno	✓ AMARILLO	Assessment done pre-deployment; rarely updated	Could benefit from continuous stakeholder feedback
I - Independiente	✓ AMARILLO	Facilitator should be external (not product team)	Often done by product team → bias risk
E - Económico	✓ VERDE	€15-25K workshops; prevents €500K+ issues	Excellent ROI

SCORE PRAGMATIC: 6.5/9 (CONDICIONADA - REDEFINICIÓN NECESARIA)

Redefinición Obligatoria: Replace "completeness" (vague) with "# stakeholder groups consulted" (concrete).

Métrica Operacional (REDEFINIDA):

MAP-2.1: Stakeholder Impact Assessment (REDEFINED)

- Baseline: 2 groups consulted (product team, executives only)
- Target: 5+ stakeholder groups consulted for each high-risk system
(Users, Data Sources, Impacted Communities, Domain Experts, Ethics)
- Measurement:
 - # distinct stakeholder groups engaged
 - # workshop sessions conducted (≥ 1 per group)
 - Documentation completeness: impact map + risk register
 - Feedback incorporated count: ($\#$ stakeholder suggestions adopted / total suggestions) $\times 100\%$
- Frequency: Pre-deployment + annual re-assessment
- Owner: Product Manager + Ethics Officer (co-own)
- Escalation: < 5 groups consulted $\rightarrow$ cannot deploy
- Process:
 - Week 1: Identify stakeholder categories
 - Week 2-3: Conduct workshops (external facilitator)
 - Week 4: Synthesize findings $\rightarrow$ impact register
 - Week 5: Present to ethics committee + document decisions
- Validation: External auditor reviews workshop notes + attendee list

2.2 Indicador: MAP-2.2 - "Risk Matrix (Impact × Likelihood) Definition"

Criterio	Evaluación	Justificación	Evidencia
P - Predictivo	✓ VERDE	Risk matrix identifies highest-impact risks early → prioritize mitigation	Predictive of failures
R - Relevante	✓ VERDE	NIST MAP-3; foundation for MANAGE function	Core risk management
A - Accionable	✓ VERDE	Scoring matrix defined → score each risk → prioritize	Clear owner: Risk Officer
G - Genuino	✓ AMARILLO	Impact/Likelihood definitions can be subjective	Need explicit definitions (personas + escenarios)
S - Significativo	✓ VERDE	Risk prioritization changes drastically with matrix	Major org implication
P - Preciso	✓ AMARILLO	Matrix scoring depends on input data quality; garbage in → garbage out	Need validated scoring data
O - Oportuno	✓ VERDE	Risk assessment quarterly; matrix stable, recalibrated semi-annual	Good frequency
I - Independiente	✗ ROJO	Risk scoring often biased toward internal perspective (missing external view)	Need external expert calibration
E - Económico	✓ VERDE	€5K matrix design; millions in risk mitigation ROI	Excellent

SCORE PRAGMATIC: 7.5/9 (CONDICIONADA - CALIBRACIÓN EXTERNA)

Condición: External risk expert annually reviews and recalibrates matrix based on actual incidents (ground truth validation).

Métrica Operacional:

MAP-2.2: Risk Matrix Definition & Use

- Baseline: Ad-hoc risk discussions; no formal matrix
- Target: Defined Impact (1-5 scale) × Likelihood (1-5 scale);
all risks scored; matrix used in go/no-go decisions
- Measurement:
 - # risks identified for each system
 - % risks with Impact×Likelihood scores
 - Correlation with actual incidents (validation check)
 - Gate adherence: (# deployment decisions using matrix / # total decisions) × 100%
- Frequency: Risk assessment quarterly; matrix recalibration semi-annual
- Owner: Chief Risk Officer + CISO
- Escalation: High-risk (Impact 4-5 × Likelihood 3+) → board review
- Matrix Definition:
 - Impact scale:
 - 1 = Negligible (1-10 people affected, <€100K)
 - 2 = Minor (10-100 people, €100K-1M)
 - 3 = Moderate (100-1K people, €1M-10M)
 - 4 = Major (1K-10K people, €10M-100M)
 - 5 = Critical (>10K people or systemic, >€100M)
 - Likelihood scale (over 12-month period):
 - 1 = Rare (<1% chance)
 - 2 = Unlikely (1-5%)
 - 3 = Possible (5-20%)
 - 4 = Likely (20-50%)
 - 5 = Almost certain (>50%)
- Validation:
 - Post-incident review: actual risk vs. forecast (calibration check)
 - Annual expert audit: external risk consultant reviews + adjusts matrix
- Tool: Risk register (JIRA or Archer); matrix visual in dashboard

IV. MÓDULO 3: MEDICIÓN (MEASURE - NIST AI RMF)

3.1 Indicador: MEASURE-3.1 - "Accuracy/Reliability Metric (on holdout test + production)"

Criterio	Evaluación	Justificación	Evidencia
P - Predictivo	✓ VERDE	Accuracy trending predicts performance degradation before major failure	ML drift early warning
R - Relevante	✓ VERDE	NIST MEASURE; core trustworthiness characteristic (Valid & Reliable)	Fundamental
A - Accionable	✓ VERDE	ML team can retrain, tune hyperparameters, collect more data	Clear ownership
G - Genuino	✓ VERDE	Accuracy = (correct predictions / total) computed on holdout set	Well-defined metric
S - Significativo	✓ VERDE	90% vs. 95% accuracy = significantly different business outcomes	Material impact
P - Preciso	✓ VERDE	Deterministic calculation from test set; error ~0%	Not an estimate
O - Oportuno	✓ VERDE	Computed weekly on holdout; monthly on production sample	Appropriate cadence
I - Independiente	✓ AMARILLO	ML team computes own metric (potential bias)	Need external validation
E - Económico	✓ VERDE	Computation is free (data already collected); high value	Excellent

SCORE PRAGMATIC: 8.5/9 (VIABLE - VALIDACIÓN EXTERNA)

Mejora Recomendada: Quarterly external audit of holdout set methodology (ensure no data leakage, proper stratification).

Métrica Operacional:

MEASURE-3.1: Model Accuracy Monitoring

- Baseline: 87% on holdout set (initial training)
- Target: ≥95% on holdout; maintain ≥94% in production
- Measurement:
 - Holdout accuracy: $(TP + TN) / (TP + TN + FP + FN)$
 - Production accuracy: sampled from last 1000 predictions
 - Stratified by demographic groups (gender, age, region) for disparity
 - Trend: Is accuracy ↑, stable, or ↓?
- Frequency: Weekly (holdout, automated); monthly (production, manual sample)
- Owner: ML Engineer + Data Scientist
- Alert thresholds:
 - YELLOW: Accuracy <95% on holdout OR ↓2% MoM trend
 - RED: Accuracy <92% on holdout OR ↓5% MoM trend
 - ACTION: <92% → retrain or rollback model
- Calculation method:
 - Holdout set: 20% of training data, held out during training
 - Stratification: Ensure demographic balance in holdout
 - No data leakage: Features not using future information
- Dashboard: Accuracy trend plot (weekly points) + alert zone visualization
- Validation: External audit quarterly of holdout construction methodology

3.2 Indicador: MEASURE-3.2 - "Fairness Metric (Demographic Parity Gap %)"

Criterio	Evaluación	Justificación	Evidencia
P - Predictivo	✓ VERDE	Early detection of fairness drift before legal liability	Predictive of discrimination complaints
R - Relevante	✓ VERDE	NIST MEASURE (Fair); EU AI Act fairness requirement	Legal requirement
A - Accionable	✓ VERDE	If gap >5%, trigger bias audit + remediation (retrain, adjust threshold)	Clear action trigger
G - Genuino	✓ VERDE	Demographic parity = approval rate difference between groups	Mathematical definition
S - Significativo	✓ VERDE	2% vs. 8% gap has profound fairness/legal implications	Materially significant
P - Preciso	✓ VERDE	Deterministic calculation; error <0.1%	Precise
O - Oportuno	✓ VERDE	Monthly automated calculation on production data	Timely
I - Independiente	✗ ROJO	Data science team owns metric definition AND validation (conflict of interest)	Need external fairness expert
E - Económico	✓ VERDE	Computation free; fairness expert review quarterly (€5K)	Excellent ROI

SCORE PRAGMATIC: 8/9 (VIALE CON CONDICIÓN)

Condición Crítica: External fairness auditor (independent firm) must validate methodology quarterly. Acceptance criteria for gap threshold must be pre-approved by Board (not ML team discretion).

Métrica Operacional:

MEASURE-3.2: Demographic Parity Monitoring

- Baseline: Unknown (first audit Q1 2026)
- Target: <5% difference in approval/recommendation rate between demographic groups
- Measurement:
 - Demographic groups: Gender (M/F), Age (18-35 / 35-55 / 55+), Nationality (EU citizen / non-EU / other)
 - Approval rate: # approved / # total for each group
 - Parity gap: $|Approval_GroupA - Approval_GroupB| / Approval_GroupB \times 100\%$
 - Report: Gap for each pair of demographic groups
- Frequency: Monthly (automated), quarterly audit (manual review + external)
- Owner: Data Science team (execution) + Ethics Officer (validation)
- Alert thresholds:
 - YELLOW: Gap 5-7.5% → escalate to Chief Architect
 - RED: Gap >7.5% → immediate board notification + mitigation planning
 - ACTION: Red → model disabled until remediation validated
- Calculation:
 - Source: Production prediction logs (approved/rejected decisions)
 - Sample: Last 10K decisions (or 90-day rolling window)
 - Stratification: Ensure sufficient sample per group (>100 per group)
 - Control for confounders: Documented and reported
- Fairness metrics computed:
 - Demographic Parity: above
 - Equalized Odds: FPR gap (false positive rate difference)
 - Calibration: Predicted probability ≈ actual outcome per group
- Dashboard: Heatmap (demographic pairs × gap %), trend lines, alert zone
- Remediation playbook if Red:
 - Step 1: Investigative analysis (root cause of disparity)
 - Step 2: Stratified performance analysis (accuracy by group)
 - Step 3: Rebalance training data or adjust decision threshold
 - Step 4: Retest on holdout (verify gap <5% before production)
 - Step 5: Board approval before re-deployment
- Validation: External fairness auditor (Aequitas, Fairness Indicators team) quarterly reviews methodology + results

3.3 Indicador: MEASURE-3.3 - "Explainability Coverage (%)"

Criterio	Evaluación	Justificación	Evidencia
P - Predictivo	✓ VERDE	Explainability → user trust → adoption; unexplained → skepticism	Trust metric
R - Relevante	✓ VERDE	NIST MEASURE (Explainable); EU AI Act Art. 14 (right to explanation)	Compliance mandate
A - Accionable	✓ VERDE	<90% coverage → implement SHAP/LIME for remaining models	Clear action
G - Genuino	✓ AMARILLO	"Explainability" can mean many things (SHAP, LIME, rule-based)	Need definition clarity
S - Significativo	✓ VERDE	50% vs. 95% coverage = vastly different user/regulator perception	Significant
P - Preciso	✓ AMARILLO	Coverage is binary (model explains or not); but quality of explanation varies	Need quality metric too
O - Oportuno	✓ VERDE	Measured quarterly or per deployment	Timely
I - Independiente	✗ ROJO	ML team often judges own explainability (biased)	Need user testing
E - Económico	✗ AMARILLO	SHAP/LIME library free, but implementation time (~40 hrs per model)	Moderate cost

SCORE PRAGMATIC: 7/9 (CONDICIONADA - DEFINICIÓN + VALIDACIÓN USUARIO)

Condiciones:

1. Define "explainability" operationally (e.g., "SHAP values + decision rule provided to user")
2. User satisfaction test: explanation useful? (target ≥6/10)

Métrica Operacional (REDEFINIDA):

MEASURE-3.3: Explainability & User Understanding

- Baseline: 15% models have explanation mechanisms
- Target: 95% models have SHAP/LIME; user satisfaction $\geq 6/10$
- Measurement:
 - Coverage: $(\# \text{ models with explanation module} / \# \text{ total models}) \times 100\%$
 - Quality: User satisfaction survey (1-10 scale, target ≥ 6)
 - Completeness: $(\% \text{ decisions getting explanation} / \% \text{ decisions eligible}) \times 100\%$
- Frequency: Quarterly coverage; bi-annual user satisfaction survey
- Owner: ML Engineer (coverage) + Product Manager (UX)
- Definition: "Explainability" = at minimum:
 - Feature importance (top 3-5 features influencing decision)
 - Decision rule (e.g., "Credit score + income ratio > threshold")
 - Presented in plain language to end user (not just ML practitioners)
- Alert thresholds:
 - YELLOW: Coverage <90%
 - RED: Coverage <80% OR user satisfaction <5/10
 - ACTION: Red $\rightarrow$ block new deployments without explainability
- User satisfaction survey:
 - Stratified sample: 100+ users per quarter
 - Questions: "Was explanation helpful?" "Did it change your mind?" etc.
 - Track by demographic group (equity check)
 - Open feedback: "What was confusing?"
- Dashboard: Coverage trend (quarterly), user satisfaction (rolling 12-month)
- Remediation: If Red $\rightarrow$ invest in better explanation UX or reconsider model use

3.4 Indicador: MEASURE-3.4 - "Security Monitoring: MTTD (Mean Time To Detect anomalies)"

Criterio	Evaluación	Justificación	Evidencia
P - Predictivo	✓ VERDE	Fast detection – fast response – minimize damage	Prevention through speed
R - Relevante	✓ VERDE	NIST MEASURE (Secure); EU AI Act, NIS2 incident reporting	Compliance metric
A - Accionable	✓ VERDE	<15min MTTD $\rightarrow$ improve SIEM ML/anomaly detection	Owner: Security team
G - Genuino	✓ VERDE	MTTD = (alert time - incident start time)	Measurable from logs
S - Significativo	✓ VERDE	2 hours vs. 15 minutes MTTD = 8x difference in damage radius	Critical
P - Preciso	✓ VERDE	Computed from SIEM logs; precise timestamp	Error <1 second
O - Oportuno	✓ VERDE	Real-time monitoring, daily aggregation	Timely
I - Independiente	✓ VERDE	SIEM is independent monitoring layer	By design
E - Económico	✓ VERDE	SIEM already deployed; MTTD reporting is free	Excellent

SCORE PRAGMATIC: 9/9 (VIABLE - APROBADO)

Métrica Operacional:

MEASURE-3.4: Security MTTD (Mean Time To Detect)

- Baseline: Unknown (no formal tracking; estimated 4-8 hours)
- Target: MTTD <15 minutes for critical alerts; <1 hour for high alerts
- Measurement:
 - $MTTD = Time_Alert - Time_EventStart$
 - Source: SIEM logs (alert timestamp vs. actual event timestamp)
 - Aggregation: Average MTTD per alert type (weekly/monthly)
 - Trending: Is MTTD improving? (YoY comparison)
- Frequency: Real-time monitoring; daily reports; monthly dashboard
- Owner: Security Operations Center (SOC)
- Alert thresholds:
 - YELLOW: MTTD >30 min for critical alerts
 - RED: MTTD >1 hour for critical alerts
 - ACTION: Red → escalation to CISO; review SIEM tuning
- Alert types tracked:
 - Model drift detection (accuracy ↓ >2% MoM)
 - Suspicious model access patterns
 - Data exfiltration attempts (model extraction)
 - Supply chain incidents (malicious package detected)
 - Compliance violations (audit trail tampering)
- Calculation:
 - For each incident: record event start time + alert trigger time
 - $MTTD = alert\ time - event\ start\ time$
 - Filter out false positives (exclude alerts with <30 min gap)
 - Aggregate: mean, median, 95th percentile MTTD per month
- Dashboard:
 - Trend: MTTD over 12 months (should be declining)
 - Distribution: 25th/50th/75th/95th percentile visualization
 - By alert type: breakout MTTD by incident category
- Improvement roadmap:
 - Current: SIEM with rule-based detection
 - Q2 2026: Add machine learning anomaly detection (predict 30% faster)
 - Q4 2026: Target MTTD <15 min for critical

V. MÓDULO 4: GESTIÓN DE RIESGOS (MANAGE - NIST AI RMF)

4.1 Indicador: MANAGE-4.1 - "MTTR (Mean Time To Remediate) for Bias/Security Incidents"

Criterio	Evaluación	Justificación	Evidencia
P - Predictivo	✓ VERDE	Fast remediation predicts organizational agility	Lagging but important indicator
R - Relevante	✓ VERDE	NIST MANAGE; EU AI Act compliance	Requirement
A - Accionable	✓ VERDE	If MTTR >30d, optimize remediation playbook	Owner: Program Manager
G - Genuino	✓ VERDE	MTTR = (resolution time - incident detection time)	Clear definition
S - Significativo	✓ VERDE	7 days vs. 45 days MTTR = vastly different risk posture	Material
P - Preciso	✓ VERDE	Tracked in incident management system	Precise tracking
O - Oportuno	✓ VERDE	Monthly aggregation; real-time dashboard	Timely
I - Independiente	✓ VERDE	Tracked independently by incident management team	No bias
E - Económico	✓ VERDE	Reporting free (data already collected)	Free

SCORE PRAGMATIC: 9/9 (VIALE - APROBADO)

Métrica Operacional:

MANAGE-4.1: Mean Time To Remediate (MTTR) - IA Incidents

- Baseline: 45 days average (current state Q1 2026)
- Target: <30 days for critical incidents; <7 days for high
- Measurement:
 - MTTR = Time_Resolved - Time_Detected
 - Source: Incident management system (JIRA/ServiceNow)
 - Aggregation: Average per severity level (monthly)
 - Trending: YoY comparison
- Frequency: Real-time tracking; monthly reporting
- Owner: Incident Response Lead
- Severity levels:
 - Critical: Bias gap >10% OR security breach confirmed
Target MTTR: <7 days
 - High: Bias gap 5-10% OR detected model drift >5%
Target MTTR: <14 days
 - Medium: Bias gap 1-5% OR minor security issue
Target MTTR: <30 days
 - Low: <1% bias gap OR non-critical finding
Target MTTR: <90 days
- MTTR stages tracked:
 - T1: Detection → Investigation start: <1 day (alert efficiency)
 - T2: Investigation → Root cause identified: <2 days (diagnostic)
 - T3: Root cause → Remediation deployed: <7 days (execution)
 - T4: Deployment → Validation complete: <3 days (testing)
- Remediation playbook (standard response processes):
 - Bias incident:
 - Step 1: Isolate model (disable if high-risk)
 - Step 2: Root cause analysis (data quality? feature engineering? training bias?)
 - Step 3: Retrain or adjust threshold
 - Step 4: Validate fairness metrics on holdout
 - Step 5: Deploy with monitoring
 - Security incident:
 - Step 1: Contain threat (isolate affected system)
 - Step 2: Forensic analysis
 - Step 3: Patch or remediate
 - Step 4: Restore with validation
- Dashboard:
 - Current MTTR by severity: Bar chart (vs. target)
 - Trend: 12-month MTTR trend (should be declining)
 - Distribution: histogram of MTTR (identify outliers)
 - By stage: which T1-T4 stage is slowest? (optimize)
- Continuous improvement:
 - Monthly review: identify incidents with MTTR >SLA
 - Root cause: why was it slow? (unclear process? resource shortage?)
 - Action: update playbook or allocate more resources

4.2 Indicador: MANAGE-4.2 - "Remediation Validation by Independent Auditor (%)"

Criterio	Evaluación	Justificación	Evidencia
P - Predictivo	✓ AMARILLO	Validation ensures no regressions; lagging indicator	Post-hoc, not predictive
R - Relevante	✓ VERDE	NIST MANAGE (manage residual risk); compliance	Requirement
A - Accionable	✓ VERDE	<100% validation → allocate auditor resources	Owner: Chief Auditor
G - Genuino	✓ VERDE	% validated = (audited remediations / total remediations)	Binary metric
S - Significativo	✓ VERDE	0% vs. 100% validation = trust difference	Strategic
P - Preciso	✓ VERDE	Count-based; error ~0%	Precise
O - Oportuno	✓ AMARILLO	Validation within 2 weeks post-remediation (delay possible)	Good but not real-time
I - Independiente	✓ VERDE	External auditor firm validates (by design)	Independence guaranteed
E - Económico	✓ AMARILLO	€10-20K audit cost per incident; can add up	Moderate cost

SCORE PRAGMATIC: 8/9 (VIALE - ECONÓMICO CONSIDERACIÓN)

Mejora: For high-frequency incidents, consider statistical sampling (audit 100% initially, then 50% if consistent).

Métrica Operacional:

MANAGE-4.2: Remediation Validation Coverage

- Baseline: 40% of critical incidents validated
- Target: 100% of critical/high incidents validated; 50% of medium (sampling)
- Measurement:
 - Validation rate: $(\# \text{ remediations audited} / \# \text{ total remediations}) \times 100\%$
 - Stratified by severity: tracking separately for critical/high/medium
 - Validation outcome: % passed audit (should be >95%)
- Frequency: Per incident (within 2 weeks); monthly aggregation
- Owner: Chief Auditor (external firm)
- Process:
 - Remediation completed by: Product/Security team
 - Validation trigger: Team submits "remediation complete" ticket
 - Auditor review: Technical audit of remediation
 - Does remediation address root cause?
 - Are metrics (fairness/security) back to acceptable?
 - Any side effects or regressions?
 - Audit trail documented?
 - Result: PASS (remediation approved) or FAIL (more work needed)
- Audit checklist per incident type:
 - For Bias incidents:
 - ☐ Retraining completed with balanced dataset
 - ☐ Fairness metrics validated on holdout (<5% gap)
 - ☐ A/B test performed (old vs. new model)
 - ☐ Decision threshold documented + approved
 - ☐ Model card updated
 - For Security incidents:
 - ☐ Root cause confirmed (e.g., model extracted? Data leaked?)
 - ☐ Patch applied + tested
 - ☐ SIEM detection logic updated (prevent recurrence)
 - ☐ Forensic report completed
 - ☐ Supply chain risk mitigated
- Dashboard:
 - Validation coverage by severity: bar chart
 - Audit pass rate: % incidents passing first audit (should be >95%)
 - Rework rate: % incidents requiring re-remediation
 - Audit cycle time: how long does validation take? (trend)
- Sampling strategy (if <100% audited):
 - Phase 1 (Q1-Q2): Audit 100% of critical/high
 - Phase 2 (Q3+): If pass rate >97%, move to 50% sampling (critical), 100% for high
 - Trigger: If pass rate drops below 95%, return to 100%

VI. TABLA RESUMEN: TODOS LOS INDICADORES + PRAGMATIC SCORES

#	Indicador	Función NIST	Pragmatic Score	Status	Acción
1.1	Formal IA Policy	GOVERN	8.5/9	VIABLE	✓ Implement
1.2	RACI Matrix	GOVERN	8/9	VIABLE	✓ Implement Q1
1.3	Risk Tolerance Quantified	GOVERN	8/9	VIABLE	✓ Define scales
1.4	IA Inventory Completeness	GOVERN	7.5/9	CONDICIONADO	⚠ Validar methodology
2.1	Stakeholder Impact Assessment	MAP	6.5/9	CONDICIONADO	⚠ Redefinir métrica
2.2	Risk Matrix Definition	MAP	7.5/9	CONDICIONADO	⚠ Calibración externa
3.1	Accuracy Monitoring	MEASURE	8.5/9	VIABLE	✓ Implement Q1
3.2	Demographic Parity Gap	MEASURE	8/9	VIABLE	✓ Audit externe
3.3	Explainability Coverage	MEASURE	7/9	CONDICIONADO	⚠ Definir + user test
3.4	Security MTTD	MEASURE	9/9	APROBADO	✓ Prioridad máxima
4.1	MTTR Remediation	MANAGE	9/9	APROBADO	✓ Prioridad máxima
4.2	Remediation Validation %	MANAGE	8/9	VIABLE	✓ Sampling strategy

VII. CONSOLIDACIÓN: MATRIZ EJECUTIVA

Por Estado de Viabilidad

✓ **APROBADOS (9/9)** - Implementar inmediatamente:

- MEASURE-3.4: Security MTTD
- MANAGE-4.1: MTTR Remediation

✓ **VIABLE (8-8.5/9)** - Implementar con ajustes menores:

- GOVERN-1.1: Formal IA Policy (ajustar frequency)
- GOVERN-1.2: RACI Matrix (bien diseñado)
- GOVERN-1.3: Risk Tolerance (definir trigger)
- MEASURE-3.1: Accuracy Monitoring (validación externa)
- MEASURE-3.2: Demographic Parity (audit externa)
- MANAGE-4.2: Validation % (sampling strategy)

 CONDICIONADO (7-7.5/9) - Implementar con revisión/redefinición:

- GOVERN-1.4: Inventory (validar completeness definition)
- MAP-2.1: Stakeholder Assessment (redefinir operacionalmente)
- MAP-2.2: Risk Matrix (calibración externa)
- MEASURE-3.3: Explainability (definición + user test)

VIII. ROADMAP DE IMPLEMENTACIÓN

Q1 2026 (Enero-Marzo)

- GOVERN-1.1: Formal policy approval (2 weeks)
- GOVERN-1.2: RACI documentation (2 weeks)
- MEASURE-3.4: MTTD monitoring live (1 week)
- MANAGE-4.1: MTTR tracking initiate (1 week)

Q2 2026 (Abril-Junio)

- MEASURE-3.1: Accuracy monitoring (automated pipeline)
- MEASURE-3.2: Fairness audit program launched
- MAP-2.2: Risk matrix calibration (external expert)
- MEASURE-3.3: Explainability framework defined

Q3-Q4 2026

- Continuous monitoring
- Refinements based on learnings
- Re-assessment against PRAGMATIC criteria
- Board reporting on KPI trends

Fin de Matriz de Evaluación PRAGMATIC Completa

Documento técnico profesional

Enero 2026 | Confidencial | España